GLOBAL INVESTORZ GROUP

GIG Backend

Architecture, security, database, working flows and the complete API reference for the GIG mobile app (Android and iOS).

97	49	48
endpoints in total	for the mobile app	for GIG staff (admin)

Version 1.0.0 · Generated 29 October 2026 from the source code (branch `test`), so the endpoint reference matches exactly what the server serves.
Repository: `gig-backend` · Stack: Node.js 22, TypeScript, Express 5, zod 4, Supabase (Postgres + Storage).

Contents

1. Overview
2. How the backend works
3. Project structure
4. Database and storage
5. Security
6. API conventions
7. Key flows, step by step
8. App screens and the APIs they call
9. Endpoint summary
10. Endpoint reference
11. Staff roles and permissions
12. Running and operating the backend
13. Changes needed in the mobile app
14. Error codes
15. Current status and open items

1. Overview

The GIG backend is the API behind the GIG mobile app. The app has two platforms (Android and iOS) and no web client; GIG staff use the separate `/admin` API. Every endpoint is served under `/api/v1`, and an interactive Swagger page is served at `/api/docs` outside production.

Area	What it covers
Auth and onboarding	Sign-up with email and phone OTP, login by email or phone + password, token refresh, logout, forgot/reset password.
Profile, files, KYC	The member's own profile and avatar, signed uploads to storage, KYC submission for Prive and Institutional.
Reviews (companies)	Company list, detail, scorecard, trends, compare, published reviews, and the 6-step review submission.
Ratings (issuers)	Issuer list and offer details, rating summary and breakdown, rating submission.
Representations	Petitions, the 9-step track, digital signing with a receipt PDF.
Roadshows	Issue summary and terms, financials in 5 currencies, DD documents, Ask Me Anything, Power Pool and Pool Power.
Learn, saved, credits, top rated	Learn content, webinars, saved items, the credit balance and ledger, and leaderboards.
Admin	Staff roles, user management, KYC decisions, moderation, content management, credits, audit log.

Membership tiers

Tier	How it is granted	What it unlocks
Observer	Granted at once when the account is created.	Browse companies, issuers, petitions, roadshows, learn; summary views only.
Prive	Requested at sign-up; granted when GIG staff approve the KYC submission.	Full analytics and reviews; submit reviews and ratings; sign petitions; ask roadshow questions; join the Power Pool.
Institutional	Requested at sign-up; granted when GIG staff approve the KYC submission.	Full analytics and reviews, DD documents, petition submission packs.

2. How the backend works

Mobile app

- Android / iOS
- Sends JSON over HTTPS
- Keeps access + refresh tokens in Keychain / Keystore
- Uploads files straight to Storage with signed URLs

→

GIG API (Express 5)

- Security headers, CORS, 100 KB body limit
- Per-IP rate limit, no-store caching
- JWT + live session check
- Tier / KYC / staff-permission guards
- zod validation of every input
- Services: business rules, hashing, encryption

→

Supabase (via supabase-js)

- `public.app_*` functions (service role only)
- Private `app` schema: users, sessions, KYC, ratings, petitions, audit
- `public` tables with RLS on, no policies
- Private Storage buckets + signed URLs

What happens on every request

1. **Request ID.** A UUID is assigned and returned in `X-Request-Id` (quote it when reporting a problem).
2. **Security headers and CORS** (helmet; in production only the listed origins). JSON bodies over 100 KB are refused.
3. **Rate limit:** 300 requests per minute per IP across the whole API (health checks excepted), stored in Postgres so it holds across every server instance. Auth routes add tighter limits (see Security).
4. **No caching:** every API response is sent with `Cache-Control: no-store`.
5. **Authentication** (protected routes): the `Authorization: Bearer` access token is verified (HS256 signature, issuer, audience, expiry), then the session is looked up in the database. A logged-out, reset, expired or suspended session is refused immediately, even if the token itself has not expired.
6. **Access guard:** the route's level is checked: any user, verified Prive, Full (verified Prive or Institutional), Institutional, or a staff permission.
7. **Validation:** path, query and body are parsed with strict zod schemas. Unknown fields are rejected; errors come back as `400 VALIDATION_FAILED` with a message per field.
8. **Service logic:** business rules run, secrets are hashed or encrypted before they reach the database.
9. **Database call:** through `callDb`, which checks the arguments and the result of every `app_*` function against a typed registry. Each function is one transaction. Read-only calls are retried up to 3 times after a network failure; writes are never sent twice (a network failure becomes `503 SERVICE_UNAVAILABLE` so the app can retry safely).
10. **Response:** `{ data }`, or `{ data, meta }` for lists. Errors always use `{ error: { code, message, fields? } }`.

> **One way into the database.** The API talks to Supabase only through supabase-js with the service-role key. There is no direct Postgres connection and no database password in the server. The app itself can never query the database: the private `app` schema is not exposed, every `public` table has Row Level Security with no policies, and no function can be executed by the public roles.

3. Project structure

```
src/
  server.ts               starts the HTTP server (warns when OTP_TEST_CODE is on)
  app.ts                  Express app: request ID, helmet, CORS, JSON limit, /api/docs, /api/v1
  config/env.ts           environment variables, validated at start-up (production guards)
  docs/                   OpenAPI spec (routes.ts) and the Swagger UI (openapi.ts)
  routes/index.ts         /api/v1 router: health checks, rate limit, every feature router
  middleware/             auth + tier guards, errors, validation, request context
  lib/
    db.ts, dbFunctions.ts the typed callDb registry of every app_* function (zod-checked)
    supabase.ts           the single supabase-js client (service role)
    auth.ts, tokens.ts    access tokens and the per-request session check
    crypto.ts, password.ts  AES-256-GCM, HMAC blind index, Argon2id
    rateLimit.ts          shared limits stored in Postgres
    audit.ts, notifier.ts audit log, OTP delivery
    idempotency.ts, storage.ts, http.ts, enums.ts, membership.ts
  modules/                one folder per feature: *.routes.ts, *.schemas.ts, *.service.ts
    auth/                 register, OTP, login, refresh, logout, password reset
    users/                /me profile and avatar; /lookups option lists
    files/  kyc/          signed uploads; KYC submissions
    catalog/  reviews/    companies, trends, compare; review submission
    ratings/              issuers, rating summary, rating submission
    representations/      petitions, timeline, signatures and receipt PDFs
    roadshows/            roadshows, financials, documents, questions, Power Pool
    learn/  webinars/  saved/  credits/  topRated/
    admin/                staff console: roles, users, KYC, moderation, content, credits, audit
  types/                  database.ts (public schema types), domain.ts
supabase/
  migrations/             SQL migrations, applied in name order, never edited once applied
  seed.sql                development data (companies, issuers, petitions)
test/                     unit/, db/ (PGlite), api/ (HTTP) and helpers/
```

4. Database and storage

Postgres on Supabase, split into two schemas. Schema changes are SQL migrations in `supabase/migrations`, pushed with the Supabase CLI (`npm run db:migrate`).

Private schema `app` (never exposed; reached only through `public.app_*` functions)

Domain	Tables
Users and onboarding	`users` (encrypted email/phone + hashes, tier, KYC status, credit balance), `user_profiles`, `user_preferences`, `lookup_options` (option lists), `signup_requests` (pending sign-ups, 1 hour), `tier_history`, `consents`
Sessions and security	`user_sessions` (hashed refresh secrets), `otp_challenges` (hashed codes, decoys), `password_reset_tickets`, `rate_limits`, `audit_logs` (append-only)
Files and KYC	`files`, `kyc_submissions`, `kyc_documents`, `follows` (follower counts on the profile)
Ratings	`issuer_ratings`, `issuer_rating_factors`, `issuer_rating_risks`, `issuer_stats`, view `issuer_cards`
Representations	`representations`, `representation_signatures`, `representation_status_history`, `representation_documents`, view `representation_cards`
Admin	`user_roles` (staff roles), `admin_requests` (idempotent staff actions)

Schema `public` (Row Level Security on, no policies: only the API's service role can use it)

Domain	Tables
Catalog and reviews	`companies`, `company_tags`, `issuers`, `issuer_tags`, `reviews`, `review_tags`, `review_attachments`, `review_versions`, `company_stats`, `company_trend_points`; views `company_cards`, `review_feed`
Learn, saved, credits	`learn_items`, `webinars`, `webinar_registrations`, `saved_items`, `credit_ledger` (append-only), `notifications` (written by staff decisions, credit grants and Pool joins)
Roadshows	`roadshows`, `roadshow_financials`, `roadshow_documents`, `roadshow_questions`, `pool_members`, `roadshow_improvement_votes`, `roadshow_offers`, `fx_rates`

Storage buckets

Bucket	Holds	Access
`avatars`	Profile photos	Public read
`kyc-documents`	KYC identity documents	Private
`review-evidence`	Evidence attached to negative reviews	Private
`signatures`, `signature-receipts`	Petition signature files and receipt PDFs	Private
`representation-documents`	Petition evidence and submission packs	Private

`roadshow-documents`, `learn-reports`	DD documents, downloadable reports	Private

Private files are only ever handed out as signed links that expire after 5 minutes.

Migrations (in order)

File	Adds
`20261027000100_catalog_reviews`	Companies, issuers, reviews, stats, trends
`20261027120000_auth_and_onboarding`	Users, profiles, preferences, sign-ups, OTP, sessions, consents, audit, rate limits, option lists
`20261027130000_reviews_use_app_users`	Reviews linked to the backend's own users
`20261027140000_files_kyc_follows`	Files, KYC submissions and documents, follows
`20261027150000_security_hardening`	Least privilege for the Supabase API roles
`20261027160000_app_functions`	The `public.app_*` functions (single way into `app`)
`20261027161000` … `20261027190000`	Ratings and Representations tables, option lists and functions
`20261027200000_learn_saved_credits_notifications`	Learn, webinars, saved items, credit ledger, notifications
`20261027201000_roadshows`	Roadshows, financials, documents, questions, Power Pool, offers, FX rates
`20261027202000_lock_down_functions`	No function is ever executable by the public roles
`20261028090000_admin`	Staff roles and every admin function
`20261028100000_signup_onboarding`	Profile, preferences and tier sent with sign-up
`20261028110000_remove_unused_endpoints`	Removes OTP login and the functions/tables of endpoints no screen uses **(pending)**
`20261029090000_onboarding_lookups`	Tier and phone country-code option lists for sign-up **(pending)**

5. Security

Identity and sessions

- **Custom authentication** (not Supabase Auth). Access token: JWT, HS256, 15 minutes, issuer and audience checked; unsigned (`alg: none`), expired, foreign or forged tokens are refused.
- **Live session check on every request**, so logout, password reset and suspension take effect immediately.
- **Refresh tokens** are single-use and rotate on every refresh (30 days idle). Re-using an old refresh token is treated as theft and ends that session. Every session ends after 90 days at most.
- **Password reset** ends every session; **suspension** by staff ends every session.

Secrets and personal data

- **Passwords:** Argon2id. 8–128 characters with upper case, lower case, a digit and a symbol; must not contain the email name or the phone number. Unknown accounts still run a password check so timing reveals nothing.
- **Email and phone** are stored encrypted (AES-256-GCM). Lookups use HMAC-SHA256 blind indexes, never the plain value.
- **Three separate 32-byte keys** (JWT, encryption, blind index); the server refuses to start if any two are equal.
- The database only ever stores hashes and ciphertext of codes, tokens and contact details.

OTP and account discovery

- 6-digit codes, valid 5 minutes, 5 wrong attempts per code, 45-second resend cooldown, 5 sends per challenge; stored as keyed hashes.
- Guesses are also limited per email/phone across every challenge and IP: 10 per hour, 20 per day.
- **No account discovery:** sign-up and forgot-password answer the same whether or not the address is registered (decoy challenges that can never verify). Login has one generic error for unknown accounts and wrong passwords.
- There is no OTP login; codes exist only for sign-up and password reset.

Rate limits (shared across servers, stored in Postgres; subjects are hashed)

Limit	Allowed	Window
Every API request, per IP	300	1 minute
Register, per IP	10	1 hour
Code sends (register / resend / forgot), per IP	20	1 hour
Code sends, per email or phone	5	1 hour
Code checks, per IP	30	15 minutes
Code guesses, per email or phone	10 / 20	1 hour / 1 day
Login, per IP	20	15 minutes
Failed logins, per account	5	15 minutes
Refresh, per IP	60	1 minute
Password reset, per IP	10	1 hour
Upload URLs / KYC submissions / ratings / signatures, per user	30 / 5 / 20 / 20	1 hour

Database, files and HTTP

- Single entry: supabase-js with the service-role key. The `app` schema is not exposed; every function is `SECURITY DEFINER` with a fixed `search_path` and executable by the service role only; every `public` table has RLS with no policies. The publishable key gets "permission denied".

- Every database call's arguments and result are validated against a typed registry; a mismatch fails safely.
- Files go to storage through signed upload URLs, only into the user's own folder, PDF/JPG/PNG up to 10 MB. Files flagged as infected are never accepted or served. Downloads are 5-minute signed links.
- Strict input validation (unknown fields rejected), 100 KB body limit, security headers (helmet), no-store caching, exact CORS origins in production.
- Idempotency keys on every submission (reviews, ratings, signatures, Pool joins) so a retry never creates a duplicate.
- Append-only audit log of sign-ups, logins (including failures), OTP failures, token reuse, logouts, password resets, onboarding, submissions and every staff action.
- **Production guards:** the server refuses to start with CORS `*`, console OTP delivery, or a fixed test OTP code. Swagger is off in production by default.

> **Tested automatically:** every protected route is checked to refuse a missing token and a forged token (taken from the API spec, so new routes are covered too), plus expired, unsigned, foreign and ended-session tokens; only the sign-in, sign-up and reset routes accept writes without a token.

6. API conventions

Topic	Rule
Base URL	`https://<host>/api/v1` (local: `http://localhost:4000/api/v1`)
Authentication	`Authorization: Bearer <accessToken>`. Tokens come from `/auth/login`, the final `/auth/otp/verify` of sign-up, and `/auth/refresh`.
Access levels	Public no token · Public+ no token, more fields when signed in · User any signed-in tier · Prive Prive with KYC approved · Full verified Prive or Institutional · Inst. Institutional with KYC approved · Staff staff permission
Success	`{ "data": … }`. Lists: `{ "data": […], "meta": { "page", "pageSize", "total" } }`
Paging	`?page=1&pageSize=20`; `pageSize` at most 100
Filters	`filter[name]=A,B`. Values within one filter are OR'd; different filters are AND'd
Errors	`{ "error": { "code", "message", "fields"? } }`; `fields` maps a field path (e.g. `metrics.transparency`) to its message. See Error codes
Submissions	Send an `Idempotency-Key` header (8–128 characters, e.g. a UUID). A retry with the same key and body returns the original result with `Idempotent-Replayed: true`; the same key with a different body is `409 IDEMPOTENCY_CONFLICT`
Rate limiting	`429 RATE_LIMITED` with a `Retry-After` header in seconds
Useful headers	Response `X-Request-Id`; request `X-App-Version` (recorded with consents and audit entries)
Codes, not labels	Option values are sent as codes (e.g. `LOW_LEVEL`, `BUSINESS_OWNER`) from `GET /lookups/{type}`

7. Key flows, step by step

Sign-up (the app's order: all screens first, OTP last)

1. **Personal, Professional and Investment details, Choose investor type:** nothing is sent yet. Every choice is loaded from the backend: `GET /lookups/{country-codes | job-profiles | investment-focus | risk-levels | investment-styles | investment-sectors | tiers}`.
2. **Tier screen:** `POST /auth/register` with name, email, phone, password, `ageConfirmed: true`, `profile`, `preferences` and `tier` (all required). Unknown option codes are refused here, before any code is sent. Returns an EMAIL and a PHONE challenge.
3. **OTP screen:** `POST /auth/otp/verify` with the EMAIL challenge → `PENDING`; then with the PHONE challenge → `COMPLETED`: the account is created with profile, preferences and tier, and `user` + `tokens` are returned. "Resend" is `POST /auth/otp/send { challengeId }` (45 s cooldown).
4. **Prive / Institutional only:** `POST /files/upload-url` (purpose `KYC_DOCUMENT`) → PUT the file to `uploadUrl` → `POST /kyc/submissions` (with consent for Prive).
5. **Profile photo:** after the account exists, upload with purpose `AVATAR` and send `PATCH /me { avatarFileId }`.
6. **Welcome screens:** `GET /me`.

Observer is granted at once. Prive and Institutional are recorded as `requestedTier` and granted when staff approve the KYC (`POST /admin/kyc/{id}/approve`). A pending sign-up expires after 1 hour; each code after 5 minutes.

Login and staying signed in

1. `POST /auth/login { identifier, password }`: identifier is an email or a phone with country code (`+919876543210`). Returns `user` and `tokens`.
2. Send `accessToken` on every call. When a call returns `401`, call `POST /auth/refresh { refreshToken }` once, store the new pair (the old refresh token no longer works), and retry.
3. `POST /auth/logout` ends the session on the server.

Forgot password

1. `POST /auth/password/forgot { identifier }` → a challenge (same answer whether or not the account exists).
2. `POST /auth/otp/verify { challengeId, code }` → `RESET_TOKEN_ISSUED` with a `resetToken` (valid 10 minutes).
3. `POST /auth/password/reset { resetToken, newPassword }` → password changed, every session ended; the user logs in again.

Submitting a review, a rating or a signature (verified Prive)

1. Evidence or signature file (if needed): `POST /files/upload-url` → PUT the file.
2. Generate one `Idempotency-Key` per submission and keep it for retries.
3. `POST /reviews`, `POST /issuers/{id}/ratings` or `POST /representations/{id}/signatures`. The response is the receipt: show it directly.
4. Reviews, ratings and questions start as pending moderation and appear publicly after staff approval.

Joining the Power Pool (verified Prive)

1. Check the balance with `GET /me/credits`.
2. `POST /roadshows/{id}/pool` with `capitalInterest` and 3+ expectations, and an `Idempotency-Key`. 1 credit is spent in the same transaction; `402 INSUFFICIENT_CREDITS` or `409 ALREADY_IN_POOL` otherwise.
3. `GET /roadshows/{id}/pool-power` shows the updated demand and heat map.

Testing without SMS or email

With `OTP_TEST_CODE=123456` in `.env` (development only), every code is `123456`. Expiry, attempt limits, rate limits and decoys still apply. Swagger (`/api/docs`) has every request body prefilled.

8. App screens and the APIs they call

Screen	Endpoints
Login	`POST /auth/login`
Forgot password → OTP → new password	`POST /auth/password/forgot`, `POST /auth/otp/verify`, `POST /auth/otp/send` (resend), `POST /auth/password/reset`
Sign-up step 1: personal details	`GET /lookups/country-codes` (phone country code)
Sign-up step 2: professional details	`GET /lookups/job-profiles`
Sign-up step 3: investment details	`GET /lookups/investment-focus`, `/risk-levels`, `/investment-styles`, `/investment-sectors`
Choose investor type	`GET /lookups/tiers`
Feature comparison: tier confirmed	`POST /auth/register`
Email + phone OTP	`POST /auth/otp/verify`, `POST /auth/otp/send`
Upload ID (Prive / Institutional)	`POST /files/upload-url`, `POST /kyc/submissions`
Loading / Investor card / Welcome	`GET /me`
Dashboard	`GET /me`, `GET /top-rated`
Profile (own)	`GET /me`, `GET /me/credits`, `PATCH /me`, `POST /files/upload-url` (avatar)
Reviews tab: list, company card, compare	`GET /companies`, `GET /companies/compare`, `POST /me/saved`
Company detail (frame, metrics, trends, resolution, reviews)	`GET /companies/{id}`, `GET /companies/{id}/trends`, `GET /companies/{id}/reviews`
Review steps 1–6 → receipt	`GET /companies?q=`, `POST /files/upload-url` (evidence), `POST /reviews`
Ratings tab, issuer detail	`GET /issuers`, `GET /issuers/{id}`, `GET /issuers/{id}/rating-summary`, `POST /me/saved`
Submit rating → receipt	`GET /lookups/rating-factors`, `GET /lookups/risk-factors`, `POST /issuers/{id}/ratings`
Representation tab, petition steps (overview, evidence, track, signers)	`GET /representations`, `GET /representations/{id}`, `GET /representations/{id}/timeline`
Sign petition → receipt	`GET /lookups/investor-types`, `POST /files/upload-url` (signature), `POST /representations/{id}/signatures`
Roadshows tab, roadshow card (issue, summary, risk factors, DD, Ask Me Anything)	`GET /roadshows`, `GET /roadshows/{id}`, `GET /roadshows/{id}/financials`, `GET /roadshows/{id}/documents/{docId}`, `GET` / `POST /roadshows/{id}/questions`
Pool Power (overview, heat map, demanded improvements, join)	`GET /roadshows/{id}/pool-power`, `GET /me/credits`, `POST /roadshows/{id}/pool`
Learn tab (play, download, bookmark)	`GET /learn`, `GET /learn/{id}`, `POST /me/saved`

Top Rated tab	`GET /top-rated?type=company|issuer`
Saved (menu)	`GET /me/saved`, `DELETE /me/saved/{type}/{id}`

Not yet called by any screen (kept pending a decision): `GET /webinars`, `POST /webinars/{id}/register`, `POST /roadshows/{id}/offers`, `GET /representations/{id}/submission`, `PATCH /reviews/{id}/resolution`. The tier comparison screen advertises these features.

9. Endpoint summary

Mobile app endpoints (49)

Method	Path (under /api/v1)	Access	Purpose
GET	`/health/live`	Public	Liveness probe
GET	`/health/ready`	Public	Readiness probe (database reachable)
POST	`/auth/register`	Public	Start sign-up (account is created after both OTPs verify)
POST	`/auth/otp/send`	Public	Resend a one-time code
POST	`/auth/otp/verify`	Public	Verify a one-time code
POST	`/auth/login`	Public	Sign in; returns access and refresh tokens
POST	`/auth/refresh`	Public	Rotate the refresh token
POST	`/auth/logout`	User	Sign out of this session
POST	`/auth/password/forgot`	Public	Start a password reset
POST	`/auth/password/reset`	Public	Reset the password with a code
GET	`/me/saved`	User	My saved items
POST	`/me/saved`	User	Save an item
DELETE	`/me/saved/:type/:id`	User	Remove a saved item
GET	`/me/credits`	User	Credit balance and ledger
GET	`/me`	User	My profile
PATCH	`/me`	User	Update my profile
POST	`/files/upload-url`	User	Signed upload URL
POST	`/kyc/submissions`	User	Submit KYC documents
GET	`/lookups/:type`	Public	Options for a selection: country codes, job profiles, preferences, tiers, ...
GET	`/companies`	Public	List companies
GET	`/companies/compare`	User	Compare companies side by side
GET	`/companies/:id`	Public+	Company header, sentiment and scorecard
GET	`/companies/:id/trends`	Full	12M / 24M / ALL trends
GET	`/companies/:id/reviews`	Public+	Published reviews
POST	`/reviews`	Prive	Submit the 6-step review
PATCH	`/reviews/:id/resolution`	Prive	Update resolution status
GET	`/issuers`	Public	List issuers
GET	`/issuers/:id`	Public	Issuer offer details
GET	`/issuers/:id/rating-summary`	Public+	Aggregate rating
POST	`/issuers/:id/ratings`	Prive	Rate an issuer
GET	`/representations`	Public	List petitions
GET	`/representations/:id`	Public+	Petition overview
GET	`/representations/:id/timeline`	Public	Track status history
GET	`/representations/:id/submission`	Full	Download the submitted pack
POST	`/representations/:id/signatures`	Prive	Sign a petition
GET	`/learn`	Public+	Learn content

Method	Path (under /api/v1)	Access	Purpose
GET	`/learn/:id`	Public+	One learn item
GET	`/webinars`	User	Upcoming or past webinars
POST	`/webinars/:id/register`	User	Register for a webinar
GET	`/top-rated`	Public	Leaderboards (company or issuer)
GET	`/roadshows`	Public	List roadshows
GET	`/roadshows/:id`	Public+	Issue summary, terms, documents
GET	`/roadshows/:id/financials`	User	3-year financials
GET	`/roadshows/:id/documents/:docId`	Full	5-minute document download URL
GET	`/roadshows/:id/questions`	User	Ask Me Anything questions
POST	`/roadshows/:id/questions`	Prive	Ask a question
POST	`/roadshows/:id/pool`	Prive	Join the Power Pool (1 credit)
GET	`/roadshows/:id/pool-power`	User	Pool participants and demand
POST	`/roadshows/:id/offers`	Inst.	Post an offer

Admin endpoints (48)

Method	Path (under /api/v1)	Access	Purpose
GET	`/admin/me`	`any staff`	My staff roles and permissions
GET	`/admin/users`	`users.read`	Search users
GET	`/admin/users/:id`	`users.read`	One user
PATCH	`/admin/users/:id`	`users.manage`	Change tier or suspend
PUT	`/admin/users/:id/roles`	`roles.manage`	Set staff roles
GET	`/admin/kyc`	`kyc.review`	KYC queue
GET	`/admin/kyc/:id`	`kyc.review`	One KYC submission
POST	`/admin/kyc/:id/approve`	`kyc.review`	Approve KYC
POST	`/admin/kyc/:id/reject`	`kyc.review`	Reject KYC
GET	`/admin/moderation/queue`	`moderation.read`	Moderation queue
GET	`/admin/moderation/:id`	`moderation.read`	One moderation item
POST	`/admin/moderation/:id/decision`	`moderation.decide`	Decide a moderation item
GET	`/admin/companies`	`content.read`	List companies
GET	`/admin/companies/:id`	`content.read`	One company
POST	`/admin/companies`	`content.manage`	Create a company
PATCH	`/admin/companies/:id`	`content.manage`	Update a company

Method	Path (under /api/v1)	Access	Purpose
DELETE	`/admin/companies/:id`	`content.manage`	Delete a company
GET	`/admin/issuers`	`content.read`	List issuers
GET	`/admin/issuers/:id`	`content.read`	One issuer
POST	`/admin/issuers`	`content.manage`	Create an issuer
PATCH	`/admin/issuers/:id`	`content.manage`	Update an issuer
DELETE	`/admin/issuers/:id`	`content.manage`	Delete an issuer
GET	`/admin/representations`	`content.read`	List representations
GET	`/admin/representations/:id`	`content.read`	One representation
POST	`/admin/representations`	`content.manage`	Create a representation
PATCH	`/admin/representations/:id`	`content.manage`	Update a representation
DELETE	`/admin/representations/:id`	`content.manage`	Soft-delete a representation
POST	`/admin/representations/:id/status`	`representations.track`	Advance the track status
POST	`/admin/representations/:id/documents`	`representations.track`	Attach documents
GET	`/admin/representations/:id/signatures`	`representations.track`	Signers with identity
POST	`/admin/representations/:id/signatures/:signatureId/remove`	`representations.track`	Remove a signature
GET	`/admin/roadshows`	`content.read`	List roadshows
GET	`/admin/roadshows/:id`	`content.read`	One roadshow
POST	`/admin/roadshows`	`content.manage`	Create a roadshow
PATCH	`/admin/roadshows/:id`	`content.manage`	Update a roadshow
DELETE	`/admin/roadshows/:id`	`content.manage`	Archive a roadshow
PUT	`/admin/roadshows/:id/financials`	`content.manage`	Replace fiscal years
POST	`/admin/roadshows/:id/documents`	`content.manage`	Attach a DD document
DELETE	`/admin/roadshows/:id/documents/:docId`	`content.manage`	Remove a DD document
POST	`/admin/roadshows/:id/questions/:qid/answer`	`questions.answer`	Publish the issuer's answer
GET	`/admin/learn`	`content.read`	List learn items
GET	`/admin/learn/:id`	`content.read`	One learn item
POST	`/admin/learn`	`content.manage`	Create a learn item

Method	Path (under /api/v1)	Access	Purpose
PATCH	`/admin/learn/:id`	`content.manage`	Update a learn item
DELETE	`/admin/learn/:id`	`content.manage`	Archive a learn item
POST	`/admin/credits/grant`	`credits.manage`	Grant or revoke credits
GET	`/admin/audit-logs`	`audit.read`	Audit trail
POST	`/admin/uploads`	`per upload target`	Signed upload URL for staff documents

10. Endpoint reference

Every endpoint with who may call it, the headers it needs, the success response, and every path parameter, query parameter and body field with its rules. Paths are shown in full (`/api/v1/…`); `:id` values are UUIDs unless noted.

Health checks 2 endpoints

Used by hosting and load balancers, not by the app. `/health/live` answers while the process runs; `/health/ready` also checks the database and returns `503` when it is unreachable. Neither is rate-limited.

GET `/api/v1/health/live` Public

Liveness probe

Who can call	No token needed
Success	200 — `{ data }`

GET `/api/v1/health/ready` Public

Readiness probe (database reachable)

Who can call	No token needed
Success	200 — `{ data }`

Authentication and sign-up 8 endpoints

Custom authentication (not Supabase Auth). Sign-up creates the account only after both the email and the phone are verified. Login takes an email, or a phone number with country code, plus the password. Access tokens last 15 minutes; refresh tokens are single-use and rotate on every refresh. See Key flows for the step-by-step order.

Error codes the app should handle: `INVALID_CREDENTIALS`, `ACCOUNT_SUSPENDED`, `OTP_INVALID`, `OTP_EXPIRED`, `OTP_ATTEMPTS_EXCEEDED`, `OTP_RESEND_COOLDOWN` (with `Retry-After`), `OTP_RESEND_LIMIT`, `SIGNUP_EXPIRED`, `ACCOUNT_EXISTS`, `INVALID_REFRESH_TOKEN`, `RESET_TOKEN_INVALID`, `RATE_LIMITED`.

POST `/api/v1/auth/register` Public

Start sign-up (account is created after both OTPs verify)

Who can call	No token needed
Success	202 — `{ data }`

Returns an EMAIL and a PHONE challenge. Verify both with POST /auth/otp/verify (with OTP_TEST_CODE=123456 in .env every code is 123456; otherwise codes are printed in the server log in dev); the second verify creates the account and returns the tokens. profile, preferences and tier are required: the app sends them from its tier screen (its OTP screen comes last), and they are applied when the account is created. Option codes come from GET /lookups/{type}.

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`name`	string	✓	length 4–100; format-checked
`email`	string	✓	length 0–254
`countryCode`	string		one of: `+91`, `+971`; default `"+91"`
`phone`	string	✓	
`password`	string	✓	length 8–128; needs lower case, upper case, digit and symbol
`ageConfirmed`	boolean	✓	must be `true`
`profile`	object	✓	no other fields allowed
`profile.experienceYears`	number or string	✓	
`profile.jobProfile`	string	✓	option code (e.g. `LOW_LEVEL`)
`profile.otherJob`	string		length 1–100
`profile.location`	string	✓	length 1–120
`preferences`	object	✓	no other fields allowed
`preferences.focus`	string[]	✓	1–1 items; option codes
`preferences.risk`	string[]	✓	1–1 items; option codes
`preferences.style`	string[]	✓	1–3 items; option codes
`preferences.sector`	string[]	✓	1–3 items; option codes
`tier`	string	✓	one of: `OBSERVER`, `PRIVE`, `INSTITUTIONAL`

EXAMPLE BODY

```
{
  "name": "Asha Mehta",
  "email": "asha.investor@example.com",
  "countryCode": "+91",
  "phone": "9876543210",
  "password": "Investor@2026",
  "ageConfirmed": true,
  "profile": {
    "experienceYears": 5,
    "jobProfile": "BUSINESS_OWNER",
    "location": "Mumbai"
  },
  "preferences": {
    "focus": ["FINANCIAL_ASSETS"],
    "risk": ["MEDIUM_LEVEL"],
    "style": ["ACTIVE_INVESTING"],
    "sector": ["TECHNOLOGY", "HEALTHCARE"]
  },
  "tier": "OBSERVER"
}
```

POST /api/v1/auth/otp/send

Public

Resend a one-time code

Who can call	No token needed
Success	202 — `{ data }`

Sends a new code for a sign-up or password-reset challenge: use the challengeId returned by /auth/register or /auth/password/forgot. Allowed once every 45 seconds, 5 times per challenge.

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`challengeId`	string (uuid)	✓	format-checked

EXAMPLE BODY

```
{
  "challengeId": "7f1c2a4e-1b2c-4d3e-8f90-123456789abc"
}
```

POST /api/v1/auth/otp/verify

Public

Verify a one-time code

Who can call	No token needed
Success	200 — `{ data }`

Sign-up: PENDING until both challenges are verified, then COMPLETED with user and tokens. Password reset: returns resetToken.

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`challengeId`	string (uuid)	✓	format-checked
`code`	string	✓	format `^\d{6}$`
`device`	object		default `{"platform":"OTHER"}`; no other fields allowed
`device.name`	string		length 1–100
`device.platform`	string		one of: `IOS`, `ANDROID`, `WEB`, `OTHER`; default `"OTHER"`

EXAMPLE BODY

```
{
  "challengeId": "00000000-0000-4000-8000-000000000000",
  "code": "123456",
  "device": {
    "name": "Swagger UI",
    "platform": "WEB"
  }
}
```

POST /api/v1/auth/login

Public

Sign in; returns access and refresh tokens

Who can call	No token needed
Success	200 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`identifier`	string	✓	length 1–254
`password`	string	✓	length 1–128
`device`	object		default `{"platform":"OTHER"}`; no other fields allowed
`device.name`	string		length 1–100
`device.platform`	string		one of: `IOS`, `ANDROID`, `WEB`, `OTHER`; default `"OTHER"`

EXAMPLE BODY

```
{
  "identifier": "asha.investor@example.com",
  "password": "Investor@2026",
  "device": {
    "name": "Swagger UI",
    "platform": "WEB"
  }
}
```

POST /api/v1/auth/refresh

Public

Rotate the refresh token

Who can call	No token needed
Success	200 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`refreshToken`	string	✓	length 1–200

POST /api/v1/auth/logout

User

Sign out of this session

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

POST /api/v1/auth/password/forgot

Public

Start a password reset

Who can call	No token needed
Success	202 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`identifier`	string	✓	length 1–254

EXAMPLE BODY

```
{
  "identifier": "asha.investor@example.com"
}
```

POST /api/v1/auth/password/reset

Public

Reset the password with a code

Who can call	No token needed
Success	200 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`resetToken`	string	✓	length 1–200
`newPassword`	string	✓	length 8–128; needs lower case, upper case, digit and symbol

EXAMPLE BODY

```
{
  "resetToken": "<resetToken from /auth/otp/verify>",
  "newPassword": "Investor@2026"
}
```

My profile, saved items and credits 6 endpoints

`GET /me` returns the profile, avatar URL, follower counts, job profile, experience, location, preferences (code + label), tier, requested tier, KYC status and onboarding progress. `PATCH /me` edits the profile; the avatar is uploaded first with `POST /files/upload-url` (purpose `AVATAR`) and then attached with `avatarFileId`.

Saved items cover companies, issuers, roadshows and learn items, each returned with a small summary. Credits: `{ balance, entries }`; the ledger is append-only and the balance can never go below 0.

GET `/api/v1/me/saved` User

My saved items

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`type`	string or string[]		

POST `/api/v1/me/saved` User

Save an item

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`type`	string	✓	one of: `COMPANY`, `ISSUER`, `ROADSHOW`, `LEARN_ITEM`
`id`	string (uuid)	✓	format-checked

DELETE `/api/v1/me/saved/:type/:id` User

Remove a saved item

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`type`	string	✓	one of: `COMPANY`, `ISSUER`, `ROADSHOW`, `LEARN_ITEM`
`id`	string (uuid)	✓	format-checked

GET `/api/v1/me/credits` User

Credit balance and ledger

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`

GET `/api/v1/me` User

My profile

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATCH `/api/v1/me` User

Update my profile

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`name`	string		length 4–100; format-checked
`experienceYears`	number or string		
`jobProfile`	string		option code (e.g. `LOW_LEVEL`)
`otherJob`	string		length 1–100
`location`	string		length 1–120
`avatarFileId`	string (uuid)		format-checked

EXAMPLE BODY

```
{
  "name": "Asha Mehta",
  "experienceYears": 5,
  "location": "Mumbai, India"
}
```

File uploads 1 endpoint

Files never pass through the API. The app asks for a signed upload URL (PDF, JPG or PNG, up to 10 MB), PUTs the file straight to Supabase Storage, then sends the returned `fileId` (or `path` for review evidence) to the endpoint that uses it. Files live under `<user id>/<random id>.<ext>`, so each user writes only to their own folder. Avatars are public; KYC documents, evidence and signatures are private.

POST `/api/v1/files/upload-url` — User

Signed upload URL

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`purpose`	string	✓	one of: `AVATAR`, `KYC_DOCUMENT`, `REVIEW_EVIDENCE`, `SIGNATURE`
`mimeType`	string	✓	one of: `application/pdf`, `image/jpeg`, `image/png`
`sizeBytes`	integer	✓	range −∞–10485760

EXAMPLE BODY

```
{
  "purpose": "AVATAR",
  "mimeType": "image/jpeg",
  "sizeBytes": 204800
}
```

KYC 1 endpoint

Prive and Institutional members submit identity documents after sign-up. One open submission per user; submitting stores the documents and the consent (time, IP, user agent, app version) and sets `kycStatus` to `PENDING` in one transaction. GIG staff approve or reject it through the admin API; approval grants the requested tier. The member sees the result as `kycStatus` in `GET /me`.

POST `/api/v1/kyc/submissions` — User

Submit KYC documents

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`documents`	object[]	✓	1–5 items
`documents[].fileId`	string (uuid)	✓	format-checked
`documents[].documentType`	string	✓	one of: `ID_PROOF`, `ADDRESS_PROOF`, `TAX_ID`, `INCORPORATION_CERTIFICATE`, `AUTHORISATION_LETTER`
`consentAccepted`	boolean		default `false`

Option lists 1 endpoint

Returns `{ code, label }` pairs. The app shows the label and sends the code. Every choice in the sign-up flow comes from here: `country-codes` (step 1), `job-profiles` (step 2), `investment-focus`, `risk-levels`, `investment-styles`, `investment-sectors` (step 3) and `tiers` (Choose investor type). Also `rating-factors`, `risk-factors` and `investor-types`. The tier and country-code lists are tested to match exactly what `POST /auth/register` accepts. Responses are cached for 5 minutes.

GET `/api/v1/lookups/:type` Public

Options for a selection: country codes, job profiles, preferences, tiers, ...

Who can call	No token needed
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`type`	string	✓	one of: `country-codes`, `job-profiles`, `investment-focus`, `risk-levels`, `investment-styles`, `investment-sectors`, `tiers`, `rating-factors`, `risk-factors`, `investor-types`

Companies (Reviews tab) and Top Rated 6 endpoints

Company list with search, sort (`relevant`, `recent`, `trending`, `top_rated`, `most_reviewed`, `improving`) and filters. Detail returns the header, sentiment split and the 5-metric scorecard; analytics (resolution lens, momentum) and trends are for Full members. Published reviews come back as `detail: "SUMMARY"` for Observers and signed-out visitors and `detail: "FULL"` for Full members. Filters use `filter[name]=A,B`: values within one filter are OR'd, separate filters are AND'd.

GET `/api/v1/companies` Public

List companies

Who can call	No token needed
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 0–100
`sort`	string		one of: `relevant`, `recent`, `trending`, `top_rated`, `most_reviewed`, `improving`; default `"relevant"`
`filter[sentiment]`	string or string[]		comma-separated list allowed
`filter[assetClass]`	string or string[]		comma-separated list allowed
`filter[resolution]`	string or string[]		comma-separated list allowed
`filter[score]`	string or string[]		comma-separated list allowed
`filter[country]`	string or string[]		comma-separated list allowed
`filter[investedStatus]`	string or string[]		comma-separated list allowed
`filter[year]`	string or string[]		comma-separated list allowed

GET `/api/v1/companies/compare` — User

Compare companies side by side

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`ids`	string or string[]	✓	

GET `/api/v1/companies/:id` — Public+

Company header, sentiment and scorecard

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/companies/:id/trends` — Full

12M / 24M / ALL trends

Who can call	Prive with KYC approved, or Institutional
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`range`	string		one of: `12M`, `24M`, `ALL`; default `"12M"`

GET `/api/v1/companies/:id/reviews` Public+

Published reviews

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`sort`	string		one of: `recent`, `oldest`, `highest`, `lowest`; default `"recent"`
`filter[sentiment]`	string or string[]		comma-separated list allowed
`filter[resolution]`	string or string[]		comma-separated list allowed
`filter[assetClass]`	string or string[]		comma-separated list allowed
`filter[investedStatus]`	string or string[]		comma-separated list allowed
`filter[year]`	string or string[]		comma-separated list allowed

GET `/api/v1/top-rated` Public

Leaderboards (company or issuer)

Who can call	No token needed
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`type`	string		one of: `company`, `issuer`; default `"company"`

Reviews 2 endpoints

Only verified Prive members can submit. The sentiment decides the required fields: **Positive** needs appreciations, a detailed review (10–800 chars) and reinvest status; **Neutral** needs mixed and detailed reviews; **Negative** needs concerns, contact status, a description and 1–5 evidence files. New reviews are `PENDING_MODERATION` and count in public numbers only after a moderator approves them. The submit response is the full receipt (receipt number, reviewer, company, status), so the receipt screen needs no second call. One active review per product (`409`).

POST `/api/v1/reviews` — Prive

Submit the 6-step review

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required) `Idempotency-Key` (required, 8–128 characters, e.g. a UUID)
Success	201 — `{ data }`

PATCH `/api/v1/reviews/:id/resolution` — Prive

Update resolution status

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`resolutionStatus`	string	✓	one of: `NOT_CONTACTED`, `CONTACTED`, `IN_PROGRESS`, `RESOLVED`, `PARTIALLY_RESOLVED`, `CLOSED_UNRESOLVED`
`followUpNote`	string		length 0–400; may be `null`

Ratings (issuers) 4 endpoints

A rating is an overall score 1–5, a flag (`POSITIVE`, `NEUTRAL`, `NEGATIVE`) for each of the 10 rating factors, and exactly 3 different risk factors. One rating per investor and issuer (`409 RATING_ALREADY_SUBMITTED`). Ratings count only once published. The summary shows the average and count to everyone; Full members also get the weighted score (newer ratings weigh more) and the full breakdown. The submit response is the receipt (`GIG-RT-YYYY-NNNNNN`).

GET `/api/v1/issuers` — Public

List issuers

Who can call	No token needed
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`sort`	string		one of: `recent`, `closing_soon`, `top_rated`, `most_rated`; default `"recent"`
`filter[assetType]`	string or string[]		comma-separated list allowed
`filter[listed]`	string		one of: `true`, `false`

GET `/api/v1/issuers/:id` — Public

Issuer offer details

Who can call	No token needed
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/issuers/:id/rating-summary` — Public+

Aggregate rating

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/issuers/:id/ratings` — Prive

Rate an issuer

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required) `Idempotency-Key` (required, 8–128 characters, e.g. a UUID)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`overallScore`	integer	✓	range 1–5
`factors`	object[]	✓	1–50 items
`factors[].code`	string	✓	format `^[A-Z0-9_]{1,40}$`
`factors[].flag`	string	✓	one of: `POSITIVE`, `NEUTRAL`, `NEGATIVE`
`riskFactors`	string[]	✓	3–3 items

Representations (petitions) 5 endpoints

Track statuses: `OPEN`, `CLOSING_SOON` (last 7 days), `CLOSED`, then staff-set `UNDER_REVIEW`, `SUBMITTED_TO_REGULATOR`, `MEETING_REQUESTED`, `MEETING_SCHEDULED`, `REGULATOR_RESPONDED`, `RESOLVED`; each response also has the app label (`trackLabel`). Signing needs a signature file (upload purpose `SIGNATURE`), a display choice (`FULL_NAME`, `INITIALS`, `ANONYMOUS`) and both consents. One signature per investor (`409 ALREADY_SIGNED`); only Prive signatures count as votes. The response has the signature ID (`GIG-XXXXXXXXX`) and a 5-minute link to the receipt PDF.

GET `/api/v1/representations` — Public

List petitions

Who can call	No token needed
Success	200 — list: `{ data: [ … ], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`sort`	string		one of: `closing_soon`, `recent`, `most_signed`, `progress`; default `"closing_soon"`
`filter[status]`	string or string[]		comma-separated list allowed
`filter[country]`	string or string[]		comma-separated list allowed
`filter[openForSigning]`	string		one of: `true`, `false`

GET `/api/v1/representations/:id` — Public+

Petition overview

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/representations/:id/timeline` — Public

Track status history

Who can call	No token needed
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/representations/:id/submission` — Full

Download the submitted pack

Who can call	Prive with KYC approved, or Institutional
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/representations/:id/signatures` Prive

Sign a petition

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required) `Idempotency-Key` (required, 8–128 characters, e.g. a UUID)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`displayMode`	string	✓	one of: `FULL_NAME`, `INITIALS`, `ANONYMOUS`
`investorType`	string		format `^[A-Z0-9_]{1,40}$`; may be `null`
`signatureFileId`	string (uuid)	✓	format-checked
`consents`	object	✓	no other fields allowed
`consents.supportSubmission`	boolean	✓	must be `true`
`consents.digitalEndorsement`	boolean	✓	must be `true`

Learn, webinars and Top Rated 4 endpoints

PREMIUM content and webinars are for Full members; others see them with `locked: true` and no content URL. Report downloads are 5-minute signed links for Full members. Cards carry the rating average and count.

GET `/api/v1/learn` Public+

Learn content

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 0–100
`sort`	string		one of: `recent`, `top_rated`; default `"recent"`
`filter[format]`	string or string[]		comma-separated list allowed
`filter[category]`	string or string[]		comma-separated list allowed
`filter[access]`	string or string[]		comma-separated list allowed

GET `/api/v1/learn/:id` — Public+

One learn item

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/webinars` — User

Upcoming or past webinars

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [ … ], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`when`	string		one of: `upcoming`, `past`; default `"upcoming"`

POST `/api/v1/webinars/:id/register` — User

Register for a webinar

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

Roadshows 9 endpoints

List and detail are public. Financials cover the latest 3 fiscal years and convert to INR, USD, EUR, GBP or AED. DD documents are 5-minute signed downloads for Full members. Ask Me Anything: Prive members ask while the roadshow is open; questions are published after moderation. **Power Pool:** a Prive member joins with a capital interest and 3+ of 8 expectations; it costs 1 credit and runs in one transaction (`402 INSUFFICIENT_CREDITS`, `409 ALREADY_IN_POOL`). Pool Power shows participants, capital interest, demand per improvement and a heat map by capital-interest quartile.

GET `/api/v1/roadshows` — Public

List roadshows

Who can call	No token needed
Success	200 — list: `{ data: [ … ], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 0–100
`state`	string		one of: `OPEN`, `CLOSED`, `ALL`; default `"OPEN"`
`sort`	string		one of: `closing_soon`, `recent`; default `"closing_soon"`
`filter[poolEnabled]`	string		one of: `true`, `false`
`filter[currency]`	string or string[]		comma-separated list allowed

GET `/api/v1/roadshows/:id` — Public+

Issue summary, terms, documents

Who can call	No token needed; a signed-in user gets personalised fields
Headers	`Authorization: Bearer <accessToken>` (optional)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/roadshows/:id/financials` — User

3-year financials

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`

GET `/api/v1/roadshows/:id/documents/:docId` Full

5-minute document download URL

Who can call	Prive with KYC approved, or Institutional
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked
`docId`	string (uuid)	✓	format-checked

GET `/api/v1/roadshows/:id/questions` User

Ask Me Anything questions

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 0–100
`sort`	string		one of: `top`, `recent`; default `"recent"`
`category`	string or string[]		

POST `/api/v1/roadshows/:id/questions` Prive

Ask a question

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`question`	string	✓	length 10–500
`category`	string		one of: `GENERAL`, `EQUITY`, `DEBT`, `INSURANCE`, `CRYPTO`, `MUTUAL_FUNDS`; default `"GENERAL"`

POST `/api/v1/roadshows/:id/pool` Prive

Join the Power Pool (1 credit)

Who can call	Prive member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required) `Idempotency-Key` (required, 8–128 characters, e.g. a UUID)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`capitalInterest`	number	✓	range −∞–1000000000000000
`expectations`	string[]	✓	one of: `BETTER_ROI_IRR`, `SHORTER_LOCK_IN`, `LOWER_ENTRY_LOAD`, `LOWER_EXIT_LOAD`, `PRIORITY_ALLOTMENT`, `FLEXIBLE_PAYMENT_TERMS`, `DISCOUNTED_OFFER_PRICE`, `REGULAR_DISCLOSURES`; 3–8 items

GET `/api/v1/roadshows/:id/pool-power` User

Pool participants and demand

Who can call	Any signed-in user (Observer, Prive or Institutional)
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/roadshows/:id/offers` Inst.

Post an offer

Who can call	Institutional member with KYC approved
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`offerPrice`	number		range −∞–1000000000000000
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`
`expectedRoi`	number		range -100–1000
`expectedIrr`	number		range -100–1000
`entryLoad`	number		range 0–100
`exitLoad`	number		range 0–100
`lockInMonths`	integer		range 0–600
`minInvestment`	number		range −∞–1000000000000000
`allotmentTerms`	string		length 1–400
`paymentTerms`	string		length 1–400
`notes`	string		length 1–2000

Admin (GIG staff) 48 endpoints

The staff API. Every route needs a signed-in account holding a staff role, plus the listed permission (see Staff roles). No staff role is `403 FORBIDDEN`; a role without the permission is `403 INSUFFICIENT_ROLE`; staff can never act on their own account, content, KYC or credits (`409 SELF_ACTION`). KYC decisions, moderation, user and role changes, credit grants and petition tracking are audited inside their database functions. The mobile app does not call these; they exist so staff can approve KYC, moderate and manage content.

GET `/api/v1/admin/me` Staff

My staff roles and permissions

Who can call	Staff permission `any staff role`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

GET /api/v1/admin/users

Staff

Search users

Who can call	Staff permission `users.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [ … ], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–254
`filter[tier]`	string or string[]		comma-separated list allowed
`filter[kycStatus]`	string or string[]		comma-separated list allowed
`filter[status]`	string or string[]		comma-separated list allowed
`filter[staff]`	string		one of: `true`, `false`

GET /api/v1/admin/users/:id

Staff

One user

Who can call	Staff permission `users.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

PATCH /api/v1/admin/users/:id

Staff

Change tier or suspend

Who can call	Staff permission `users.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`tier`	string		one of: `OBSERVER`, `PRIVE`, `INSTITUTIONAL`
`status`	string		one of: `ACTIVE`, `SUSPENDED`
`reason`	string	✓	length 5–500

PUT `/api/v1/admin/users/:id/roles` Staff

Set staff roles

Who can call	Staff permission `roles.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`roles`	string[]	✓	one of: `ADMIN`, `MODERATOR`, `ANALYST`, `SUPPORT`; 0–4 items

GET `/api/v1/admin/kyc` Staff

KYC queue

Who can call	Staff permission `kyc.review`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`sort`	string		one of: `oldest`, `newest`; default `"oldest"`
`filter[status]`	string or string[]		comma-separated list allowed
`filter[tier]`	string or string[]		comma-separated list allowed

GET `/api/v1/admin/kyc/:id` Staff

One KYC submission

Who can call	Staff permission `kyc.review`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/kyc/:id/approve` — Staff

Approve KYC

Who can call	Staff permission `kyc.review`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/kyc/:id/reject` — Staff

Reject KYC

Who can call	Staff permission `kyc.review`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`reason`	string	✓	length 5–500

GET `/api/v1/admin/moderation/queue` — Staff

Moderation queue

Who can call	Staff permission `moderation.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`filter[type]`	string or string[]		comma-separated list allowed
`filter[status]`	string or string[]		comma-separated list allowed

GET `/api/v1/admin/moderation/:id` Staff

One moderation item

Who can call	Staff permission `moderation.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`type`	string	✓	one of: `REVIEW`, `RATING`, `QUESTION`, `OFFER`

POST `/api/v1/admin/moderation/:id/decision` Staff

Decide a moderation item

Who can call	Staff permission `moderation.decide`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`type`	string	✓	one of: `REVIEW`, `RATING`, `QUESTION`, `OFFER`
`decision`	string	✓	one of: `APPROVE`, `REJECT`, `REQUEST_CHANGES`, `REMOVE`
`note`	string		length 1–2000

GET `/api/v1/admin/companies` Staff

List companies

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`state`	string		one of: `ACTIVE`, `DELETED`, `ALL`; default `"ACTIVE"`
`sort`	string		one of: `recent`, `name`; default `"recent"`
`filter[assetClass]`	string or string[]		comma-separated list allowed
`filter[country]`	string or string[]		comma-separated list allowed
`filter[verified]`	string		one of: `true`, `false`

GET `/api/v1/admin/companies/:id` Staff

One company

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/companies` Staff

Create a company

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`name`	string	✓	length 2–120
`assetClass`	string	✓	one of: `EQ`, `MF`, `INS`, `BND`, `PMS`, `BRK`, `RE`, `CRY`
`country`	string	✓	one of: `IN`, `AE`, `OTHER`
`logoUrl`	string (uri)		length 0–1000; default `null`; may be `null`
`description`	string		length 1–2000; default `null`; may be `null`
`verified`	boolean		default `false`
`tags`	string[]		0–20 items; default `[]`

PATCH `/api/v1/admin/companies/:id` Staff

Update a company

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`name`	string		length 2–120
`assetClass`	string		one of: `EQ`, `MF`, `INS`, `BND`, `PMS`, `BRK`, `RE`, `CRY`
`country`	string		one of: `IN`, `AE`, `OTHER`
`logoUrl`	string (uri)		length 0–1000; may be `null`
`description`	string		length 1–2000; may be `null`
`verified`	boolean		
`tags`	string[]		0–20 items

DELETE `/api/v1/admin/companies/:id` Staff

Delete a company

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/admin/issuers` Staff

List issuers

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`state`	string		one of: `ACTIVE`, `DELETED`, `ALL`; default `"ACTIVE"`
`filter[assetType]`	string or string[]		comma-separated list allowed
`filter[listed]`	string		one of: `true`, `false`

GET `/api/v1/admin/issuers/:id`

Staff

One issuer

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/issuers`

Staff

Create an issuer

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`name`	string	✓	length 2–120
`instrument`	string	✓	length 1–60
`assetType`	string	✓	length 1–40
`exchange`	string		length 1–60; default `null`; may be `null`
`openDate`	string (date)		format-checked; default `null`; may be `null`
`closeDate`	string (date)		format-checked; default `null`; may be `null`
`isListed`	boolean		default `false`
`minLot`	integer		default `null`; may be `null`
`lotUnit`	string		length 1–20; default `"shares"`
`priceMin`	number		range 0–1000000000000000; default `null`; may be `null`
`priceMax`	number		range 0–1000000000000000; default `null`; may be `null`
`offerSize`	number		range 0–1000000000000000; default `null`; may be `null`
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`; default `"INR"`
`useOfFunds`	string		length 1–200; default `null`; may be `null`
`lockIn`	string		length 1–60; default `null`; may be `null`
`prePostRatio`	string		length 1–30; default `null`; may be `null`
`tags`	string[]		0–20 items; default `[]`

PATCH `/api/v1/admin/issuers/:id` Staff

Update an issuer

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`name`	string		length 2–120
`instrument`	string		length 1–60
`assetType`	string		length 1–40
`exchange`	string		length 1–60; may be `null`
`openDate`	string (date)		format-checked; may be `null`
`closeDate`	string (date)		format-checked; may be `null`
`isListed`	boolean		
`minLot`	integer		may be `null`
`lotUnit`	string		length 1–20
`priceMin`	number		range 0–1000000000000000; may be `null`
`priceMax`	number		range 0–1000000000000000; may be `null`
`offerSize`	number		range 0–1000000000000000; may be `null`
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`
`useOfFunds`	string		length 1–200; may be `null`
`lockIn`	string		length 1–60; may be `null`
`prePostRatio`	string		length 1–30; may be `null`
`tags`	string[]		0–20 items

DELETE `/api/v1/admin/issuers/:id` Staff

Delete an issuer

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

GET `/api/v1/admin/representations` Staff

List representations

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`state`	string		one of: `ACTIVE`, `ALL`; default `"ACTIVE"`
`filter[status]`	string or string[]		comma-separated list allowed

GET `/api/v1/admin/representations/:id` Staff

One representation

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/representations` Staff

Create a representation

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`title`	string	✓	length 5–200
`description`	string		length 0–500; default `""`
`asks`	string[]		0–10 items; default `[]`
`whyItMatters`	string		length 0–4000; default `""`
`category`	string		length 1–60; default `null`; may be `null`
`country`	string	✓	one of: `IN`, `AE`, `OTHER`
`tags`	string[]		0–10 items; default `[]`
`regulators`	string[]		0–10 items; default `[]`
`goal`	integer	✓	range 1–10000000
`opensAt`	string (date-time)		format-checked
`closesAt`	string (date-time)	✓	format-checked

PATCH `/api/v1/admin/representations/:id` Staff

Update a representation

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`title`	string		length 5–200
`description`	string		length 0–500
`asks`	string[]		0–10 items
`whyItMatters`	string		length 0–4000
`category`	string		length 1–60; may be `null`
`country`	string		one of: `IN`, `AE`, `OTHER`
`tags`	string[]		0–10 items
`regulators`	string[]		0–10 items
`goal`	integer		range 1–10000000
`opensAt`	string (date-time)		format-checked
`closesAt`	string (date-time)		format-checked

DELETE `/api/v1/admin/representations/:id` Staff

Soft-delete a representation

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/representations/:id/status`

Staff

Advance the track status

Who can call	Staff permission `representations.track`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`status`	string	✓	one of: `UNDER_REVIEW`, `SUBMITTED_TO_REGULATOR`, `MEETING_REQUESTED`, `MEETING_SCHEDULED`, `REGULATOR_RESPONDED`, `RESOLVED`
`note`	string		length 1–2000
`documents`	object[]		0–10 items; default `[]`
`documents[].title`	string	✓	length 1–200
`documents[].documentType`	string	✓	one of: `EVIDENCE`, `SUBMISSION_PACK`, `REGULATOR_RESPONSE`, `MEETING_MINUTES`
`documents[].path`	string	✓	format-checked
`documents[].mimeType`	string	✓	one of: `application/pdf`, `image/jpeg`, `image/png`
`documents[].sizeBytes`	integer	✓	range 1–26214400

POST `/api/v1/admin/representations/:id/documents`

Staff

Attach documents

Who can call	Staff permission `representations.track`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`documents`	object[]	✓	0–10 items
`documents[].title`	string	✓	length 1–200
`documents[].documentType`	string	✓	one of: `EVIDENCE`, `SUBMISSION_PACK`, `REGULATOR_RESPONSE`, `MEETING_MINUTES`
`documents[].path`	string	✓	format-checked
`documents[].mimeType`	string	✓	one of: `application/pdf`, `image/jpeg`, `image/png`
`documents[].sizeBytes`	integer	✓	range 1–26214400

GET `/api/v1/admin/representations/:id/signatures`

Staff

Signers with identity

Who can call	Staff permission `representations.track`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`includeRemoved`	string		one of: `true`, `false`

POST `/api/v1/admin/representations/:id/signatures/:signatureId/remove`

Staff

Remove a signature

Who can call	Staff permission `representations.track`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked
`signatureId`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`reason`	string	✓	length 5–500

GET `/api/v1/admin/roadshows`

Staff

List roadshows

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`filter[status]`	string or string[]		comma-separated list allowed

GET `/api/v1/admin/roadshows/:id`

Staff

One roadshow

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/roadshows`

Staff

Create a roadshow

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`issuerId`	string (uuid)	✓	format-checked
`title`	string	✓	length 2–160
`summary`	string		length 1–4000; default `null`; may be `null`
`typeOfIssue`	string	✓	length 1–60
`instruments`	string	✓	length 1–60
`noOfInstruments`	integer		default `null`; may be `null`
`offerPrice`	number		range 0–1000000000000000; default `null`; may be `null`
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`; default `"INR"`
`lockIn`	string		length 1–60; default `null`; may be `null`
`maturity`	string		length 1–60; default `null`; may be `null`
`convertibility`	string		length 1–60; default `null`; may be `null`
`callable`	boolean		default `false`
`couponRate`	number		range 0–100; default `null`; may be `null`
`riskFactors`	string[]		0–20 items; default `[]`
`opensAt`	string (date-time)		format-checked; default `null`; may be `null`
`closesAt`	string (date-time)	✓	format-checked
`poolEnabled`	boolean		default `false`
`status`	string		one of: `DRAFT`, `PUBLISHED`, `ARCHIVED`; default `"DRAFT"`

PATCH `/api/v1/admin/roadshows/:id` — Staff

Update a roadshow

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`slug`	string		length 0–80; format `^[a-z0-9]+(-[a-z0-9]+)*$`
`issuerId`	string (uuid)		format-checked
`title`	string		length 2–160
`summary`	string		length 1–4000; may be `null`
`typeOfIssue`	string		length 1–60
`instruments`	string		length 1–60
`noOfInstruments`	integer		may be `null`
`offerPrice`	number		range 0–1000000000000000; may be `null`
`currency`	string		one of: `INR`, `USD`, `EUR`, `GBP`, `AED`
`lockIn`	string		length 1–60; may be `null`
`maturity`	string		length 1–60; may be `null`
`convertibility`	string		length 1–60; may be `null`
`callable`	boolean		
`couponRate`	number		range 0–100; may be `null`
`riskFactors`	string[]		0–20 items
`opensAt`	string (date-time)		format-checked; may be `null`
`closesAt`	string (date-time)		format-checked
`poolEnabled`	boolean		
`status`	string		one of: `DRAFT`, `PUBLISHED`, `ARCHIVED`

DELETE `/api/v1/admin/roadshows/:id` — Staff

Archive a roadshow

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

PUT `/api/v1/admin/roadshows/:id/financials` Staff

Replace fiscal years

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`years`	object[]	✓	0–10 items
`years[].fiscalYear`	integer	✓	range 1990–2100
`years[].revenue`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].ebitda`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].netProfit`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].totalAssets`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].totalLiabilities`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].netWorth`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].totalDebt`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].cashAndEquivalents`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].operatingCashFlow`	number		range -1000000000000000–1000000000000000; may be `null`
`years[].eps`	number		range -1000000000000000–1000000000000000; may be `null`

POST `/api/v1/admin/roadshows/:id/documents` Staff

Attach a DD document

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`title`	string	✓	length 1–160
`docType`	string	✓	one of: `PROSPECTUS`, `FINANCIAL_STATEMENT`, `LEGAL_OPINION`, `RATING_REPORT`, `DUE_DILIGENCE`, `OTHER`
`path`	string	✓	format-checked
`sizeBytes`	integer		default `null`; may be `null`
`sortOrder`	integer		range 0–1000; default `0`

DELETE `/api/v1/admin/roadshows/:id/documents/:docId` — Staff

Remove a DD document

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked
`docId`	string (uuid)	✓	format-checked

POST `/api/v1/admin/roadshows/:id/questions/:qid/answer` — Staff

Publish the issuer's answer

Who can call	Staff permission `questions.answer`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked
`qid`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`answer`	string	✓	length 1–4000
`featured`	boolean		

GET `/api/v1/admin/learn` — Staff

List learn items

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`q`	string		length 1–100
`filter[status]`	string or string[]		comma-separated list allowed
`filter[format]`	string or string[]		comma-separated list allowed
`filter[access]`	string or string[]		comma-separated list allowed

GET `/api/v1/admin/learn/:id` Staff

One learn item

Who can call	Staff permission `content.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST `/api/v1/admin/learn` Staff

Create a learn item

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`title`	string	✓	length 2–200
`summary`	string		length 1–2000; default `null`; may be `null`
`format`	string	✓	one of: `VIDEO`, `ARTICLE`, `REPORT`, `PODCAST`
`category`	string		length 1–60; default `null`; may be `null`
`access`	string		one of: `FREE`, `PREMIUM`; default `"FREE"`
`thumbnailUrl`	string (uri)		length 0–1000; default `null`; may be `null`
`contentUrl`	string (uri)		length 0–1000; default `null`; may be `null`
`durationSeconds`	integer		range −∞–86400; default `null`; may be `null`
`downloadPath`	string		format-checked; default `null`; may be `null`
`status`	string		one of: `DRAFT`, `PUBLISHED`, `ARCHIVED`; default `"DRAFT"`

PATCH /api/v1/admin/learn/:id

Staff

Update a learn item

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — `{ data }`

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`title`	string		length 2–200
`summary`	string		length 1–2000; may be `null`
`format`	string		one of: `VIDEO`, `ARTICLE`, `REPORT`, `PODCAST`
`category`	string		length 1–60; may be `null`
`access`	string		one of: `FREE`, `PREMIUM`
`thumbnailUrl`	string (uri)		length 0–1000; may be `null`
`contentUrl`	string (uri)		length 0–1000; may be `null`
`durationSeconds`	integer		range −∞–86400; may be `null`
`downloadPath`	string		format-checked; may be `null`
`status`	string		one of: `DRAFT`, `PUBLISHED`, `ARCHIVED`

DELETE /api/v1/admin/learn/:id

Staff

Archive a learn item

Who can call	Staff permission `content.manage`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	204 — no body

PATH PARAMETERS

Field	Type	Req.	Rules
`id`	string (uuid)	✓	format-checked

POST /api/v1/admin/credits/grant

Staff

Grant or revoke credits

Who can call	Staff permission `credits.manage`
Headers	`Authorization: Bearer <accessToken>` (required) `Idempotency-Key` (required, 8–128 characters, e.g. a UUID)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`userId`	string (uuid)	✓	format-checked
`delta`	integer	✓	range -10000–10000
`note`	string	✓	length 3–400

GET `/api/v1/admin/audit-logs` Staff

Audit trail

Who can call	Staff permission `audit.read`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	200 — list: `{ data: [...], meta: { page, pageSize, total } }`

QUERY PARAMETERS

Field	Type	Req.	Rules
`page`	integer		range 1–∞; default `1`
`pageSize`	integer		range 1–100; default `20`
`filter[action]`	string or string[]		comma-separated list allowed
`filter[actionPrefix]`	string		format `^[a-z0-9_.]{1,100}$`
`filter[actorId]`	string (uuid)		format-checked
`filter[from]`	string (date-time)		format-checked
`filter[to]`	string (date-time)		format-checked

POST `/api/v1/admin/uploads` Staff

Signed upload URL for staff documents

Who can call	Staff permission `per upload target`
Headers	`Authorization: Bearer <accessToken>` (required)
Success	201 — `{ data }`

REQUEST BODY (JSON)

Field	Type	Req.	Rules
`target`	string	✓	one of: `REPRESENTATION_DOCUMENT`, `ROADSHOW_DOCUMENT`, `LEARN_REPORT`
`mimeType`	string	✓	one of: `application/pdf`, `image/jpeg`, `image/png`
`sizeBytes`	integer	✓	

11. Staff roles and permissions

Staff are ordinary accounts with one or more roles in `app.user_roles`. Roles are read on every request, so a change (or a suspension) applies at once.

Permission	ADMIN	MODERATOR	ANALYST	SUPPORT	Covers
`users.read`	✓			✓	Search members; one member's account and contact details (each view audited)
`users.manage`	✓				Change tier, suspend, reactivate
`roles.manage`	✓				Grant and revoke staff roles
`kyc.review`	✓			✓	KYC queue, documents, approve and reject
`moderation.read`	✓	✓	✓		Moderation queue
`moderation.decide`	✓	✓			Approve, reject, request changes, take down
`content.read`	✓	✓	✓	✓	Companies, issuers, petitions, roadshows, learn (all states)
`content.manage`	✓				Create, edit and delete content; roadshow and learn uploads
`representations.track`	✓	✓			Petition status, documents, signature removal
`questions.answer`	✓	✓			Publish issuer answers
`credits.manage`	✓				Grant and revoke credits
`audit.read`	✓				Audit trail

The first admin is created once in the Supabase SQL editor; after that admins grant roles with `PUT /admin/users/{id}/roles`:

```
insert into app.user_roles (user_id, role)
select id, 'ADMIN' from app.users where public_id = '<user id>';
```

12. Running and operating the backend

Environment variables (`.env`, never committed)

Variable	Purpose	Default
`NODE_ENV`	`development`, `test` or `production`	`development`
`PORT`	HTTP port	`4000`
`CORS_ORIGIN`	Allowed origins, comma-separated; `*` is refused in production	`*`
`TRUST_PROXY`	Number of proxies in front of the API (load balancer = 1), for real client IPs	`0`
`SUPABASE_URL`, `SUPABASE_SERVICE_ROLE_KEY`	The single database entry (service role). Keep the key secret	required
`JWT_ACCESS_SECRET`	32 random bytes, base64: signs access tokens	required
`JWT_ISSUER`, `JWT_AUDIENCE`	Token issuer and audience	`gig-backend`, `gig-app`
`ACCESS_TOKEN_TTL_SECONDS`	Access token lifetime (60–3600)	`900`
`REFRESH_TOKEN_IDLE_DAYS`, `SESSION_MAX_DAYS`	Refresh idle timeout and absolute session lifetime	`30`, `90`
`DATA_ENCRYPTION_KEY`, `BLIND_INDEX_KEY`	32 random bytes each, base64: PII encryption and lookup hashes (all three keys must differ)	required
`OTP_DELIVERY`	How codes are sent; only `console` exists today (refused in production)	`console`
`OTP_TEST_CODE`	Development only: every code is this 6-digit value (refused in production)	unset
`API_DOCS`	Force Swagger on or off	on except production

Generate a key: `node -e "console.log(require('crypto').randomBytes(32).toString('base64'))"`

Scripts

Command	What it does
`npm run dev`	Development server with auto-restart (also restarts when `.env` changes)
`npm run build` / `npm start`	Compile to `dist/` / run the compiled server
`npm test`	Whole test suite (no database or `.env` needed: database tests use PGlite)
`npm run typecheck`, `npm run lint`	Strict TypeScript and strict type-checked lint
`npx supabase login`, `npm run db:link`	Once per machine: sign in and link to the Supabase project
`npm run db:migrate`	Apply new migrations to Supabase (run manually)
`npm run db:seed`	First time: all migrations, then `supabase/seed.sql`

Changing the database

- Add a new migration file named after the latest one (e.g. `20261101090000_feature.sql`); never edit a migration that has been pushed.
- A new `app_*` function must also be declared in `src/lib/dbFunctions.ts`; the contract tests fail until both match.
- Stats with time-weighted scores need a nightly recompute (e.g. pg_cron): `select public.recompute_all_company_stats(); select app.recompute_all_issuer_stats();`

Quality gates

683 automated tests in 28 files: request validation, every database function against a real Postgres (PGlite), every endpoint through HTTP, access rules per tier and KYC, the Swagger spec matching the served routes, and the authentication checks on every protected route. Type check, lint and build must all pass before a change is merged.

13. Changes needed in the mobile app

The app currently runs on mock data. To integrate with this API:

- **OTP input:** 6 boxes instead of 4, for sign-up and reset.
- **Call register from the tier screen** with everything collected (personal, professional and investment details, tier), then show the email + phone OTP screen for **every** tier.
- **Prive and Institutional:** the same email + phone OTP screen as Observer, then the ID upload. The separate phone verification screen is no longer needed.
- **18+ confirmation:** add a checkbox; send `ageConfirmed: true` only after the user confirms.
- **Every sign-up choice from the backend:** load country codes, job profiles, the 4 preference lists and the tiers from `/lookups` instead of the app's constants; show the label, send the code. Job profile is a single choice; experience is a whole number of years.
- **Phone country code selector** on step 1, filled from `GET /lookups/country-codes`.
- **Profile photo:** upload after the account exists (`AVATAR` upload, then `PATCH /me`).
- **Login field** takes an email or a phone with country code; sign-up sends the country code (`+91` default, or `+971`).
- **Forgot password** needs a "new password" screen.
- **Tokens:** keep them in the Keychain / Keystore; on `401`, refresh once and retry.
- **Colours** for tabs and cards currently come from mock data; move them to a theme file during integration.
- A **logout** button calling `POST /auth/logout`.

14. Error codes

Status	Code	Meaning
400	`VALIDATION_FAILED`	Some fields are invalid; see `fields`
400	`OTP_INVALID`, `OTP_EXPIRED`, `OTP_CHALLENGE_INVALID`	Wrong code (with attempts left), expired code, or a challenge that has ended
400	`RESET_TOKEN_INVALID`	The reset token is wrong, used or expired
401	`UNAUTHENTICATED`	No token, or an invalid/expired token or session
401	`INVALID_CREDENTIALS`, `INVALID_REFRESH_TOKEN`	Wrong email/phone or password; refresh token not valid (log in again)
402	`INSUFFICIENT_CREDITS`	Not enough credits to join the Power Pool
403	`FORBIDDEN`, `KYC_REQUIRED`, `PREMIUM_CONTENT`	Wrong tier; KYC not approved; content for Full members
403	`ACCOUNT_SUSPENDED`, `INSUFFICIENT_ROLE`	Suspended account; staff role without the permission
404	`NOT_FOUND`, `SUBMISSION_NOT_AVAILABLE`	Not found; no submission pack yet
409	`CONFLICT`, `ACCOUNT_EXISTS`, `IDEMPOTENCY_CONFLICT`	Duplicate; email/phone already registered (after both codes verified); same key, different body
409	`KYC_ALREADY_PENDING`, `TIER_NOT_REQUESTED`	A KYC submission is already under review; no Prive/Institutional tier requested
409	`RATING_ALREADY_SUBMITTED`, `ALREADY_SIGNED`, `ALREADY_IN_POOL`	One rating per issuer, one signature per petition, one Pool membership per roadshow
409	`REPRESENTATION_CLOSED`, `ROADSHOW_CLOSED`, `POOL_NOT_ENABLED`, `WEBINAR_ENDED`	The item is no longer open for this action
409	`SELF_ACTION`, `SLUG_TAKEN`, `ALREADY_REMOVED`, `QUESTION_REJECTED`, `DOCUMENT_ALREADY_ATTACHED`	Admin rules (staff acting on themselves, duplicate slugs, repeated actions)
410	`SIGNUP_EXPIRED`	The pending sign-up expired; register again
413 / 415	`PAYLOAD_TOO_LARGE`, `UNSUPPORTED_ENCODING`	Body over 100 KB; unsupported body encoding
429	`RATE_LIMITED`, `OTP_ATTEMPTS_EXCEEDED`, `OTP_RESEND_COOLDOWN`, `OTP_RESEND_LIMIT`	Too many requests (see `Retry-After`); too many wrong codes; resend too soon; too many resends
500	`INTERNAL`	Unexpected error (details are never sent outside development)
503	`SERVICE_UNAVAILABLE`, `FX_RATE_UNAVAILABLE`	Database unreachable for a moment (safe to retry); currency rate missing

15. Current status and open items

> **Apply the pending migration:** run `npm run db:migrate` to apply `20261028110000_remove_unused_endpoints.sql` (removes OTP login and the functions and tables of endpoints that no screen uses) and `20261029090000_onboarding_lookups.sql` (tier and country-code option lists; until it is applied, `/lookups/tiers` and `/lookups/country-codes` return empty lists).

Item	Status
Scope rule	The backend keeps only endpoints that a current app screen uses; features without a screen are added when the app gets them.
Endpoints advertised in the tier table but without a screen	Webinars (2), Institutional "post offer", petition submission pack, review resolution update: kept, pending a decision.
Admin API	No staff console exists yet; the API is needed for KYC approval, moderation and content.
SMS and email delivery	Not chosen yet. Codes are printed in the server log in development; production will not start until a real provider is added to `src/lib/notifier.ts`.
Notifications	Written by staff decisions, credit grants and Pool joins; there is no inbox screen, so no endpoint reads them yet.
Top Rated	Leaderboards exist for companies and issuers; the app's Roadshows and Representation leaderboards need a decision (list sorting or a new ranking).
Roadshow reels	Like, comment and follow (company) buttons have no backend yet.
Background jobs	FX rate feed and the nightly stats recompute still need scheduling.